Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

List of teammates–

S.no	Name	College	Contact
1	Agalya .M	Tiruppur kumaran college for women	agal4312@gmail.com
2	Pavitha .S	Tiruppur kumaran college for women	pavisenthil1104@gmail.com
3	Abinaya Sri .P	Tiruppur kumaran college for women	abinayasri9366@gmail.com
4	Jaya Priya .S	Tiruppur kumaran college for women	rajeshaj900@gmail.com
5	Mythili Priya .R	Tiruppur kumaran college for women	mythilipriya026@gmail.com

Project Details

Title: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Abstract:

This project focuses on integrating the Zscaler security platform with Identity Providers (IdPs) such as Microsoft Entra ID (Azure AD), Okta, and on-premises Active Directory (AD). The main objective is to create a secure and centralized authentication system that allows users to access Zscaler services using a single identity. By enabling Single Sign-On (SSO), users can securely access internet and cloud applications without managing multiple credentials.The integration uses industry-standard protocols such as SAML, OpenID Connect (OIDC), and SCIM to ensure secure communication between Zscaler and the identity providers. Authentication is handled by trusted corporate directories where security policies like Multi-Factor Authentication (MFA) are enforced. In addition, SCIM enables automated user provisioning and de-provisioning, reducing administrative effort and improving access management.

Overview

The integration of Zscaler with identity providers like Microsoft Entra ID (Azure AD), Okta, and Active Directory helps organizations manage user authentication and authorization in a centralized and secure way. Instead of maintaining separate user accounts in Zscaler, the system relies on existing corporate identity platforms.Through Single Sign-On (SSO), users can log in once and securely access multiple applications and services protected by Zscaler. Security measures such as Multi-Factor Authentication (MFA) further enhance protection by verifying the user's identity before granting access.The integration also supports automated user management through SCIM, which synchronizes user information between the identity provider and Zscaler. This ensures that user access is updated automatically when employees join, change roles, or leave the organization.

Use Case Scenario 1: Online Examination System Access

Scenario:

A university student needs to access the internal online examination system from home to complete a scheduled test. Instead of granting access to the entire university network, ZPA allows the student to connect only to the exam portal after verifying identity through the university authentication system.

Output:

• User identity verified: Exam_Student_Group
• Access scope defined: Limited to Online Examination Portal
• Security enforcement: Multi-Factor Authentication required before exam login
• Connection restricted: Access allowed only to Exam Application Server
• No lateral movement: Student cannot access internal academic or administrative systems

Use Case Scenario 2: Library Staff Access to Digital Archive Server

Scenario:

A library staff member needs access to a digital archive server to upload and manage academic resources. ZPA ensures the staff member can securely connect to the archive server without exposing other internal resources.

Output:

• User identity verified: Library_Staff_Group
• Access scope defined: Limited to Digital Archive Server
• Policy enforcement: Access allowed only from authorized staff accounts
• Security enforcement: Multi-Factor Authentication enabled
• Restricted network visibility: Staff cannot access finance or HR systems

Use Case Scenario 3: Placement Officer Access to Recruitment Portal

Scenario:

A university placement officer needs access to the internal recruitment portal to coordinate campus placements and manage company job postings. ZPA grants access only to the placement system.

Output:

• User identity verified: Placement_Officer_Group
• Access scope defined: Limited to Recruitment Management Portal
• Security enforcement: Role-based access control applied

Use Case Scenario 4: System Administrator Access to Network Monitoring Tool

Scenario:

A system administrator needs remote access to the network monitoring dashboard to check server health and network performance. ZPA allows access only to the monitoring application.

Output:

• User identity verified: System_Admin_Group

• Access scope defined: Limited to Network Monitoring Dashboard

• Security enforcement: Multi-Factor Authentication required

• Connection restricted: Access allowed only to Monitoring Server

• Security control: Administrator cannot access unrelated internal applications

Use Case Scenario 5: Guest Researcher Access to Collaboration Platform

Scenario:

A visiting researcher collaborating with the university needs access to a collaboration platform to share research documents. ZPA provides restricted access to the collaboration tool only.

Output:

• User identity verified: Guest_Researcher_Group

• Access scope defined: Limited to Research Collaboration Platform

• Policy enforcement: Access granted only during the research collaboration period

• Restricted connection: Access limited to Collaboration Application Server

• Network segmentation: Guest cannot access internal university databases

Stage-1

Title Of the Project: -

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview: -

The integration of Zscaler Zero Trust Exchange with enterprise Identity Providers (IdPs) transforms how organizations secure access to applications and resources. Traditional security models relied on VPNs and perimeter defenses, often granting excessive network access. In contrast, the Zero Trust approach verifies identity at the application layer rather than the network layer. Integrating Zscaler with IdPs such as Microsoft Entra ID, Okta, and Active Directory creates a unified identity system across the organization. This ensures consistent authentication regardless of user location or device while eliminating duplicate directories and manual account management. Modern protocols such as SAML, OIDC, and SCIM support secure authentication and automated user provisioning, enabling a true Zero Trust security model.

Integration with Microsoft Entra ID enables seamless Single Sign-On using SAML 2.0 and allows organizations to apply Conditional Access policies such as device compliance, location restrictions, and risk-based authentication. SCIM-based provisioning automatically synchronizes user accounts and group memberships, reducing administrative effort and ensuring immediate access updates. Similarly, Okta integration provides a flexible identity management solution using OIDC authentication and automated lifecycle management. Okta's Universal Directory centralizes user identities, while adaptive multi-factor authentication strengthens security during access requests.

For organizations with existing on-premises infrastructure, Active Directory integration is enabled through the Zscaler Authentication Bridge, which securely connects cloud services to internal domain controllers via LDAP. This allows authentication and group synchronization without requiring inbound firewall rules, preserving existing infrastructure while enabling cloud-based Zero Trust security.

List of Vulnerability Table —

S.no	Vulnerability Name	CWE/CVE - No
1	Injection	CWE-564
2	Software and Data Integrity Failures	CWE-426
3	Cryptographic Failures	CWE-331
4	Insecure Design	CWE-656
5	Broken Access Control	CWE-377
6	Security Misconfiguration	CWE-537
7	Vulnerable and Outdated Components	CWE-1104
8	Identification and Authentication Failures	CWE-384
9	Security Logging and Monitoring Failures	CWE-778
10	Server-Side Request Forgery (SSRF)	CWE-918

REPORT:-

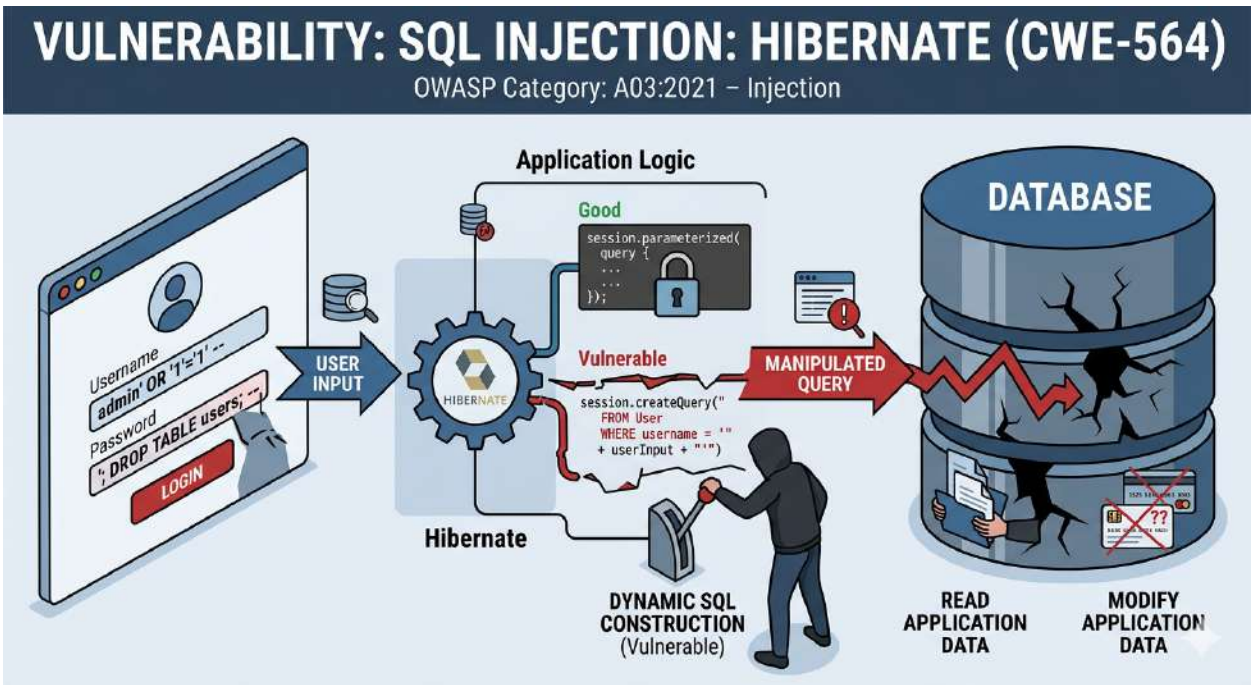
1.Vulnerability name : Injection

CWE-564 : SQL Injection: Hibernate

OWASP Category: A03:2021 – Injection

Description : Using Hibernate to execute a dynamic SQL statement built with user-controlled input can allow an attacker to modify the statement's meaning or to execute arbitrary SQL commands.

Business Impact: Read Application Data; Modify Application Data



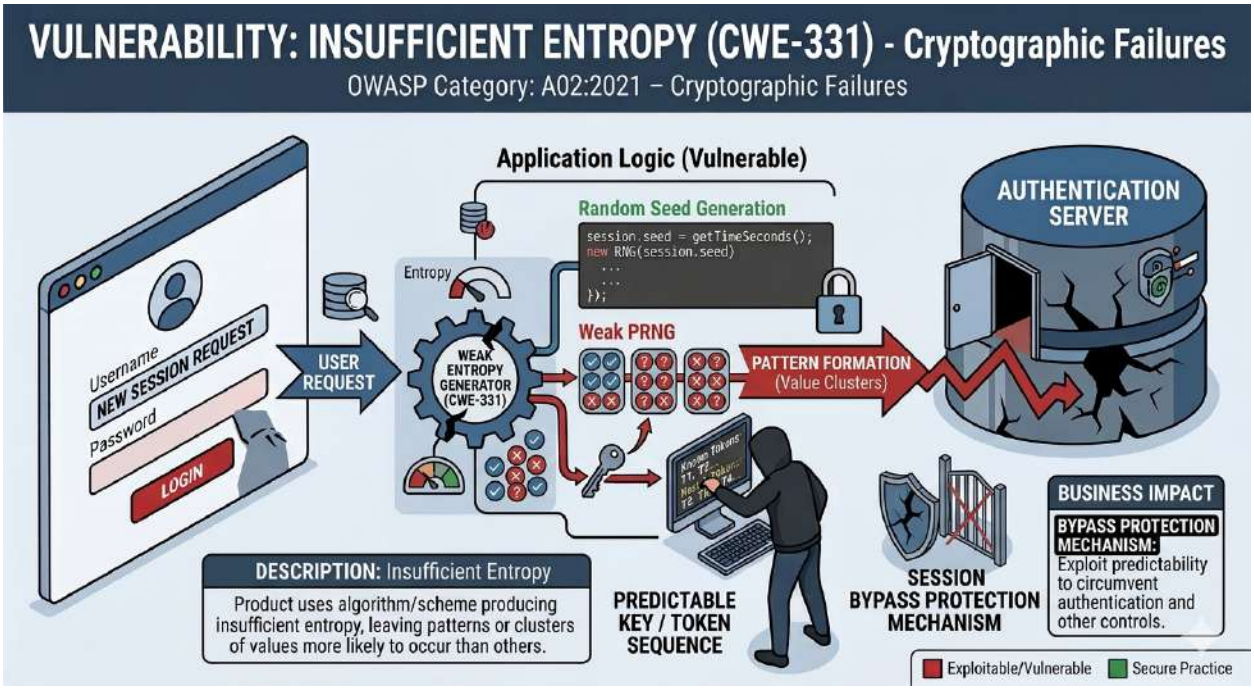
2.Vulnerability name : Cryptographic Failures

CWE- 331: Insufficient Entropy

OWASP Category: A02:2021 – Cryptographic Failures

Description: The product uses an algorithm or scheme that produces insufficient entropy, leaving patterns or clusters of values that are more likely to occur than others.

Business Impact: Bypass Protection Mechanism



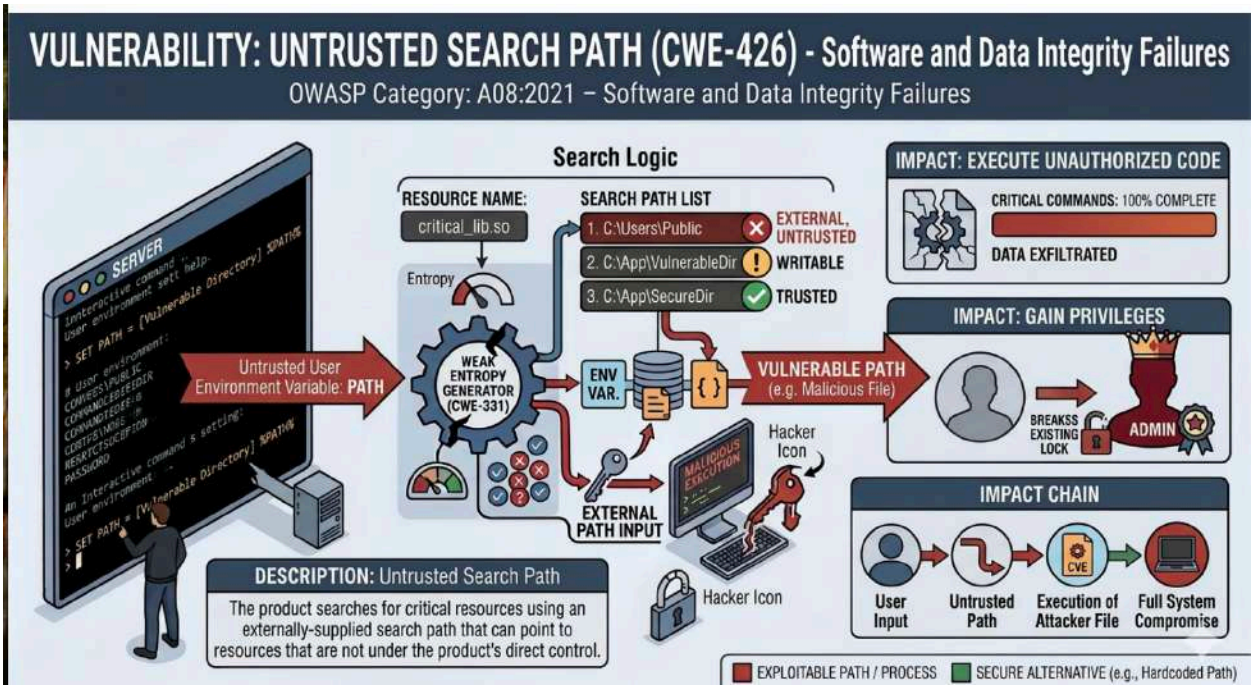
3. Vulnerability name : Software and Data Integrity Failures

CWE- 426: Untrusted Search Path

OWASP Category: A08:2021 – Software and Data Integrity Failures

Description: The product searches for critical resources using an externally-supplied search path that can point to resources that are not under the product's direct control.

Business Impact: Gain Privileges or Assume Identity; Execute Unauthorized Code or Commands



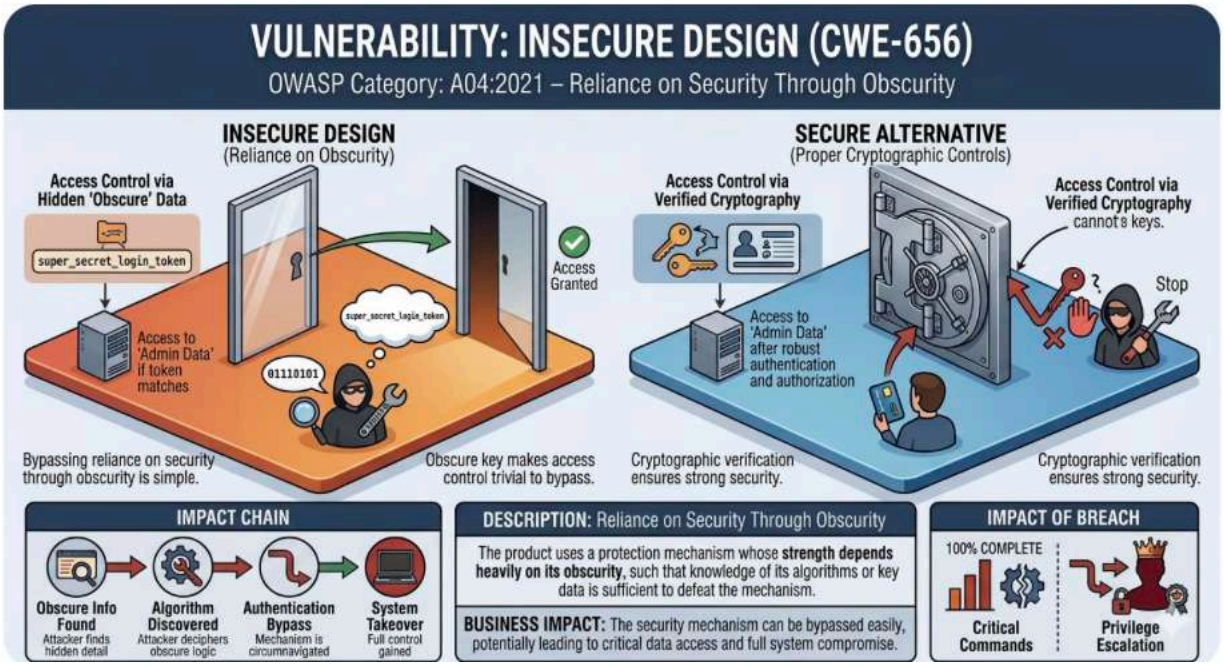
4. Vulnerability name : Insecure Design

CWE-656: Reliance on Security Through Obscurity

OWASP Category: A04:2021 – Insecure Design

Description: The product uses a protection mechanism whose strength depends heavily on its obscurity, such that knowledge of its algorithms or key data is sufficient to defeat the mechanism.

Business Impact: The security mechanism can be bypassed easily.



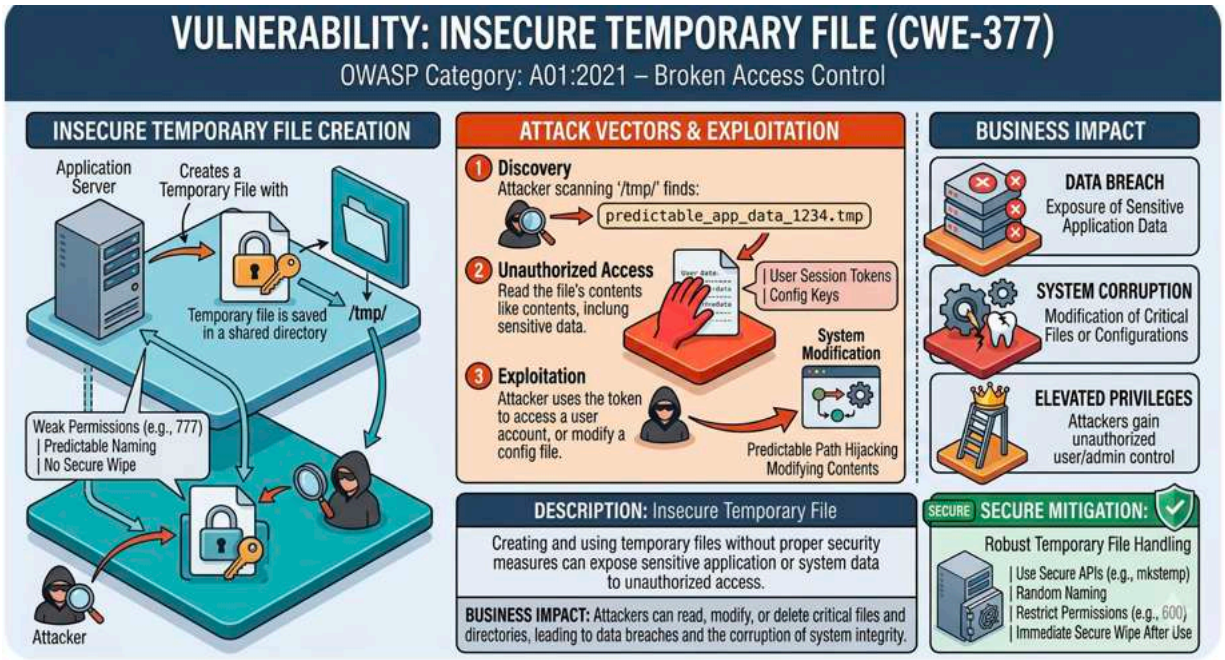
5.Vulnerability Name: Insecure Temporary File

CWE: CWE-377

OWASP Category: A01:2021 – Broken Access Control

Description: Creating and using temporary files without proper security measures can expose sensitive application or system data to unauthorized access.

Business Impact: Attackers can read, modify, or delete critical files and directories, leading to data breaches and the corruption of system integrity.



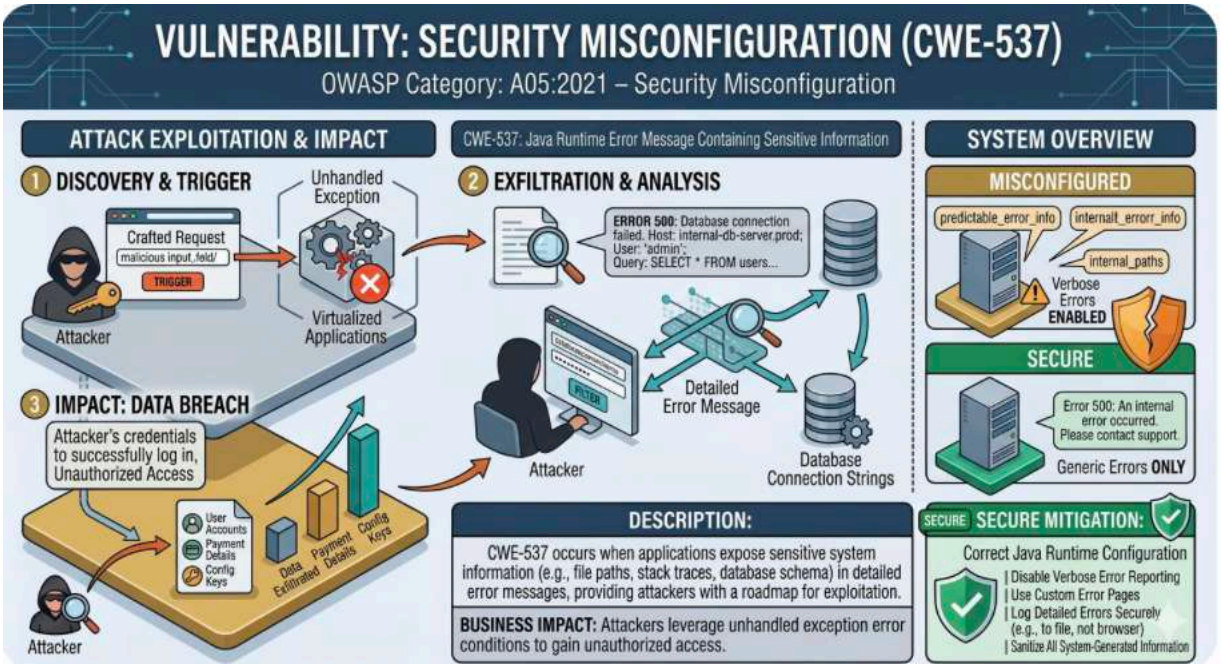
6. Vulnerability name : Security Misconfiguration

CWE-537: Java Runtime Error Message Containing Sensitive InformationOWASP

Category: A05:2021 – Security Misconfiguration

Description: In many cases, an attacker can leverage the conditions that cause unhandled exception errors in order to gain unauthorized access to the system

Business Impact: Read Application Data



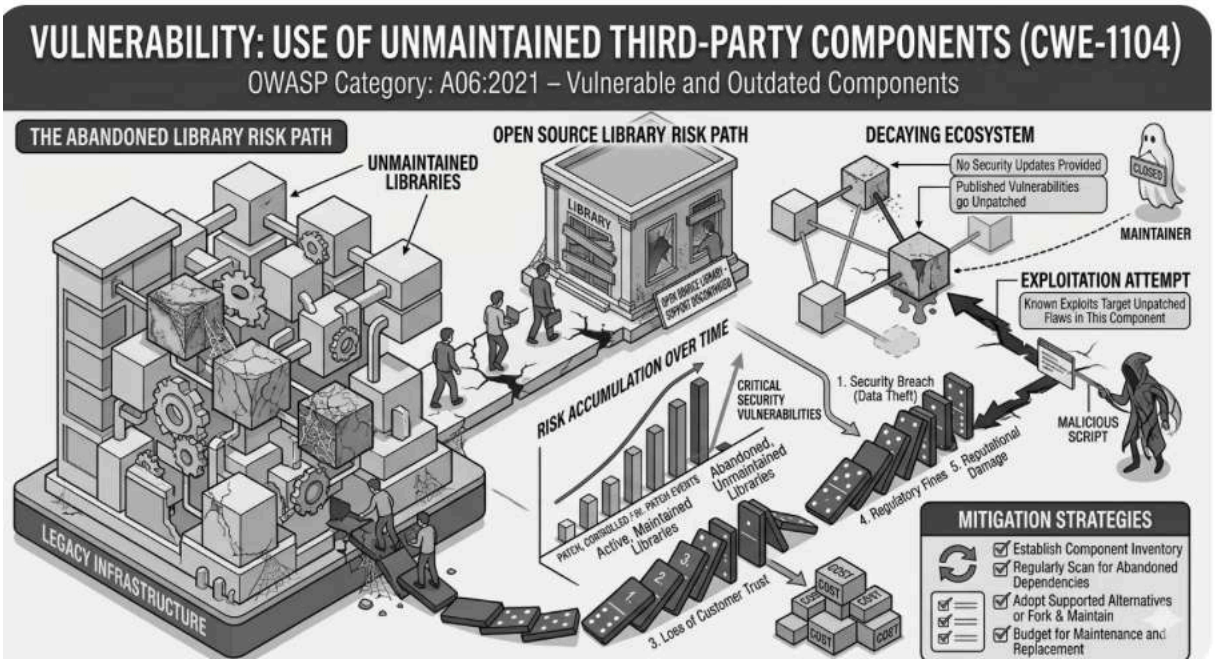
7. Vulnerability name :

CWE-1104: Use of Unmaintained Third Party ComponentsOWASP

Category: A06:2021 – Vulnerable and Outdated Components

Description: The product relies on third-party components that are not actively supported or maintained by the original developer or a trusted proxy for the original developer.

Business Impact: Reduce Maintainability; Varies by Context



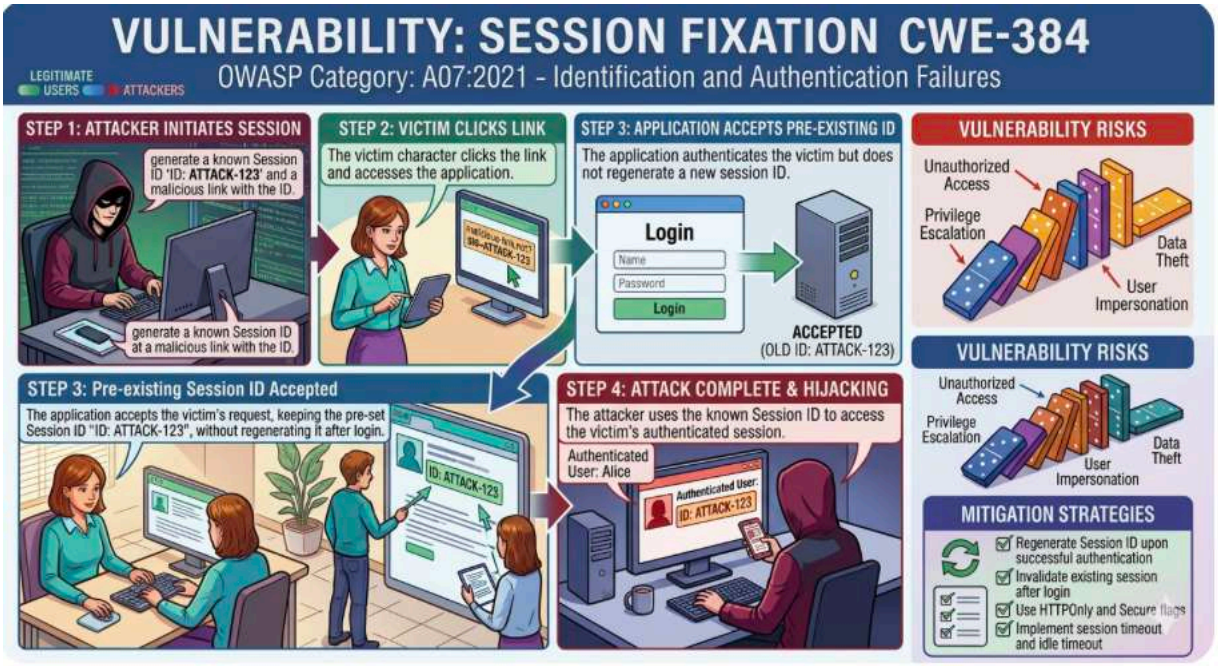
8.Vulnerability Name: Session Fixation

CWE: CWE-384

OWASP Category: A07:2021 – Identification and Authentication Failures

Description: The application authenticates a user or establishes a new session without invalidating existing session identifiers, which allows an attacker to hijack or steal authenticated sessions.

Business Impact: This vulnerability enables attackers to gain unauthorized privileges or assume a user's identity to perform sensitive actions on their behalf.



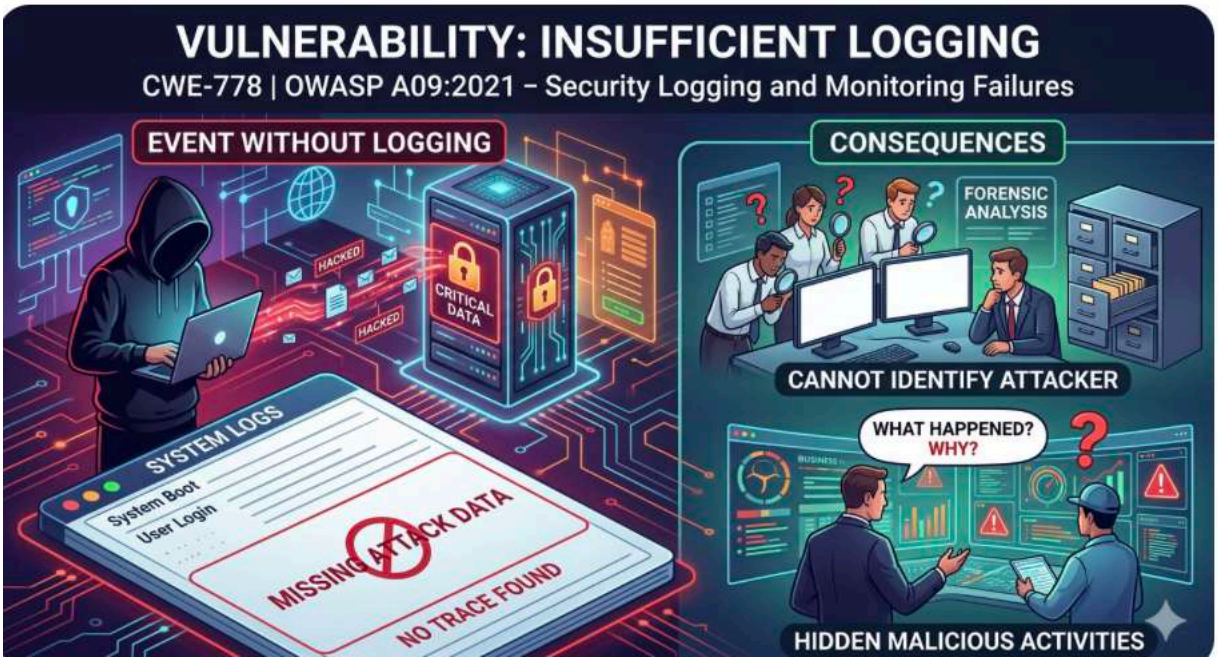
9. Vulnerability Name: Insufficient Logging

CWE: CWE-778

OWASP Category: A09:2021 – Security Logging and Monitoring Failures

Description: When a security-critical event occurs, the product either fails to record the event or omits essential details required for an accurate audit trail.

Business Impact: Malicious activities remain hidden and forensic analysis becomes impossible, preventing the organization from discovering the cause of problems or identifying the source of an attack.

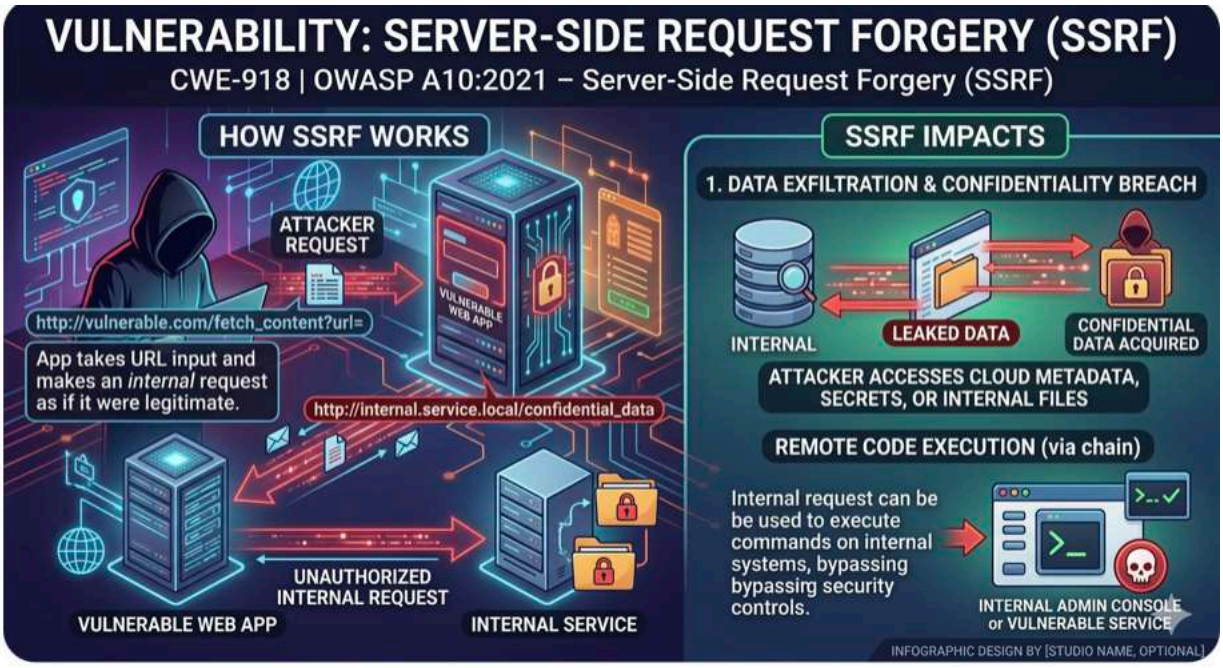


10.Vulnerability Name: Server-Side Request Forgery (SSRF)

CWE: CWE-918

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The web server receives a URL from an upstream component and retrieves the contents without sufficiently ensuring that the request is being sent to an expected or safe destination.



Stage 2

Overview :-

Nessus is a widely used vulnerability scanning tool developed by Tenable. It is designed to identify security weaknesses in computer systems, networks, and web applications. Nessus works as a remote vulnerability scanner, meaning it can analyze a target system without needing to install software directly on that system. Instead, it sends various probes and requests to the target host to detect possible vulnerabilities.

Nessus uses a large collection of plugins to detect different types of security issues. Each plugin is designed to identify a specific vulnerability, misconfiguration, or security risk in operating systems, network services, or applications. The tool contains thousands of plugins that are regularly updated to detect newly discovered vulnerabilities and threats.

When a scan is initiated, Nessus first performs a host discovery process to identify active devices on the network. After identifying the target host, the scanner checks open ports and services running on the system. Based on the detected services, Nessus runs the relevant plugins to test for known vulnerabilities such as outdated software versions, weak encryption protocols, missing security patches, and configuration issues.

After completing the scan, Nessus generates a detailed vulnerability report. The report includes the vulnerability name, severity level (such as low, medium, or high), plugin number, affected port, description of the vulnerability, and recommended solutions to fix the issue. This helps security administrators understand potential risks and take appropriate remediation actions.

Nessus can scan various targets including single hosts, networks, servers, and web applications. It also allows scans to be scheduled automatically or executed manually depending on organizational requirements. Because of its comprehensive vulnerability database, easy-to-use interface, and detailed reporting capabilities, Nessus is widely used by security professionals to improve system security and maintain a strong cybersecurity posture.

Overall, Nessus plays an important role in identifying security weaknesses before attackers can exploit them. By regularly performing vulnerability scans and applying recommended fixes, organizations can significantly reduce security risks and protect their systems, data, and network infrastructure.

LIST OF VULNERABILITY:

S.no	Vulnerability name	Severity	Plugins
1	Apache Tomcat	MIXED	43111
2	Web Servers Detection	INFO	10107
3	Port scanners	INFO	11219
4	Service detection	INFO	22964
5	CGI abuses	INFO	106658

Vulnerability Scan Report

1. Apache Tomcat (Multiple Issues)

Severity: MIXED

Family: Web Servers

Plugin ID: 43111

Description: This plugin identifies Apache Tomcat services running on the target system. It gathers critical information such as server type, version, and configuration details to detect potential vulnerabilities within the software.

Business Impact: If exploited, attackers could gain unauthorized access, disrupt services, or steal sensitive data, compromising both system availability and organizational security.

Solution: Ensure Apache Tomcat is updated to the latest secure version. Regularly apply security patches and harden the server configuration according to industry best practices.

2. Web Server Detection

Severity: INFO

Family: Web Servers

Plugin ID: 10107

Description: This plugin detects the presence of a web server and collects basic configuration data. While used for informational purposes, it establishes the baseline of the network's visible attack surface.

Business Impact: The presence of a web server may expose system details that could assist in planning further unauthorized activities if the server is not properly secured.

Solution: No direct fix is required for informational findings. Ensure the server is properly configured, regularly updated, and protected with current security patches.

3. Port Scanners

Severity: INFO

Family: Port scanners

Plugin ID: 11219

Description: This plugin identifies open ports and services responding to network requests, indicating which ports are accessible on the target system.

Business Impact: Open ports provide information about running services, which could be used to identify potential entry points if the services are vulnerable.

Solution: Review all open ports and disable any unnecessary services. Configure firewalls and network security rules to restrict access to only required ports.

4. Service Detection

Severity: INFO

Family: Service detection

Plugin ID: 22964

Description: This plugin enumerates the specific services running on discovered open ports of the target system.

Business Impact: Exposed services provide information about the system and potential points of interaction.

Solution: Disable any non-essential services. Ensure required services are kept updated, hardened, and secured.

5. CGI Abuses / Script Detection

Severity: INFO

Family: CGI abuses

Plugin ID: 106658

Description: This plugin checks for possible misuse or risky configurations in Common Gateway Interface (CGI) scripts on the web server.

Business Impact: Improper CGI configurations may allow for the exploitation of web server vulnerabilities.

Solution: Remove unused CGI scripts, update server software, and apply strict access controls to the CGI directory.

Stage 3

Title: Integrate Zscaler with Identity Providers(IdPs) such as Azure AD, Okta, and Active Directory for seamless authentication and authorization.

Identity:

Identity is the primary factor used to verify and authenticate users before granting access to applications or network resources. User identities are typically managed through centralized identity providers such as Microsoft Entra ID, Okta, or Active Directory. These systems ensure that only authorized users can access services. Authentication methods like passwords, Single Sign-On (SSO), and Multi-Factor Authentication (MFA) help strengthen identity verification and reduce unauthorized access risks.

Device Posture:

Device posture refers to the security status of the device used to access a network or application. Security checks may include verifying whether the device has updated antivirus software, the latest security patches, and proper system configurations. If a device does not meet the required security standards, access may be restricted or limited. This helps organizations prevent insecure or compromised devices from accessing sensitive resources.

Application Risk:

Application risk refers to the potential security threats associated with specific applications. Some applications may carry higher risks due to vulnerabilities, outdated versions, or exposure to malicious activities. Security systems analyse application behaviour and classify applications based on risk levels. Based on this evaluation, organizations can allow, block, or restrict access to certain applications to maintain security.

Context-Aware Access:

Context-aware access is a security approach that evaluates multiple factors such as user identity, device security status, location, and application risk before granting access. Instead of relying on a single authentication factor, the system continuously analyses contextual information to make dynamic access decisions. This approach aligns with Zero Trust security principles, ensuring that access is granted only when the user and device meet the required security conditions.

Conclusion

Artificial Intelligence (AI) plays an important role in Human Resource Management (HRM). It helps organizations improve recruitment, employee management, and decision-making processes. AI technologies analyse large amounts of data and help HR professionals work more efficiently. With proper implementation, AI can enhance productivity, improve employee experience, and support organizational growth.

Future Scope:

1. Future of Web Application Testing (WAT)

* AI and Machine Learning Integration: Moving beyond traditional manual testing, AI and ML will be used to automate repetitive tasks like test case generation and execution. These technologies are expected to identify complex patterns and anomalies that manual testing might miss.

* Focus on Security: As web applications become more vital for business, there will be an increased emphasis on identifying and mitigating security vulnerabilities early in the development lifecycle.

2. Future of the Testing Process

* Shift-Left Testing: A move toward integrating testing earlier in the Software Development Life Cycle (SDLC), allowing for the early detection and prevention of defects.

* Automation Testing: Automation is becoming a standard to save time and resources, particularly for regression testing.

3. Future Scope of SOC / SIEM

* Zero Trust Maturity: Moving toward a mature Zero Trust architecture that utilizes real-time risk assessment and automated security policies.

* Advanced Threat Detection: Implementing Endpoint Detection and Response (EDR) and SOAR (Security Orchestration, Automation, and Response) platforms to enable automated incident response.

Stage 1: Vulnerability Assessment

* Identification: Identifying vulnerabilities within the web security system to understand the security posture.

* Analysis: Analyzing reports to gain insights into potential threats and prioritize security measures.

*

Stage 2: Infrastructure Modernization

* Legacy Replacement: Replacing legacy VPN architecture with a cloud-native Zscaler Zero Trust solution.

* Application-Centric Model: Shifting from network-centric to application-centric security to reduce the attack surface.

Stage 3: Identity & Access Management Integration

* Single Sign-On (SSO): Enabling SSO capabilities across all Zscaler services.

* Policy Enforcement: Implementing Multi-Factor Authentication (MFA) and conditional access based on user identity and context.

* Provisioning: Automating user provisioning via SCIM to reduce administrative overhead and ensure immediate de-provisioning.

Topics explored: owasp top 10, scanning, vulnerabil

Tools explored: The screen also features elements of a video conference or online meeting, with user profiles for "Gautami Girikala" visible in small windows.